

במפגש השמיני של הקורס, המרצה מיכאל המשיך את הדיון במודלים של **Cyber Kill Chain** ו-**MITRE ATT&CK**, תוך התמקדות מרכזית באבטחת שרשרת האספקה ובחולשות טכנולוגיות המאפשרות חדירה לארגון.¹

להלן סיכום הנושאים המרכזיים שעלו בשיעור:

1. שרשרת האספקה - החוליה החלשה

המרצה הדגיש כי שרשרת האספקה היא לרוב החלק הפגיע ביותר בארגון בשל חוסר תאימות (Compliance) אבטחתית בין ספקי השירות לארגון^{1, 2}. תוקפים מעדיפים לתקוף ספקים קטנים או חברות מיקור חוץ כדי להשתמש בהם כ"דלת אחורית" לארגונים גדולים ומאובטחים יותר^{3, 4}.

2. איומים פנימיים מול חיצוניים

- **איום פנימי (Insider Threat):** עובד מתוך הארגון יכול לגרום נזק כבד משמעותית מתוקף חיצוני, כיוון שהוא מכיר את נקודות התורפה ויודע היכן נמצאים האדמינים ובעלי ההרשאות הגבוהות⁵.
- **העלאת הרשאות (Privilege Escalation):** תוקף חיצוני מנסה להשיג הרשאות של משתמש זוטר ואז להגדילן כדי להגיע לליבת המערכת, בעוד שתוקף פנימי כבר נמצא בתוך "החומה"⁵.

3. מקרי בוחן של תקיפות וקבוצות תקיפה

- **קבוצת APT-19:** קבוצת תקיפה סינית ותיקה המתמקדת בגניבת קניין רוחני ופטנטים ממגזרים ביטחוניים, אנרגיה ופיננסים⁶.
- **פרצת 3CX:** דוגמה קריטית שבה תוקפים החדירו קובץ DLL נגוע לתוך "גרסת המאסטר" של המוצר בתהליך האריזה (Packaging). כתוצאה מכך, הקוד הזדוני הופץ אוטומטית ל-600,000 לקוחות כחלק מעדכון גרסה סטנדרטי^{7, 8}.

4. חולשות בפרוטוקולים וכלים טכנולוגיים

- **ARP Spoofing:** ניצול פרוטוקול ה-ARP הישן (בן כ-45 שנה) שאינו בודק את אמינות החבילות, מה שמאפשר התקפות "אדם באמצע" (Man-in-the-Middle) בתוך הרשת⁹.
- **זום ו-WebEx:** המרצה סקר באגים שאפשרו כניסה לא מורשת לפגישות והשתלטות על הקלטות ומסמכים רגישים בתקופת הקורונה^{4, 10}.
- **איומים פיזיים:** הוצג סרטון המדגים כבלי USB מסוג C הכוללים מעבד זעיר ומשדר Wi-Fi, המסוגלים לנטר הקשות מקלדת (Keylogging) ולהעביר דאטה מהמחשב לתוקף מרחוק¹¹.

5. אסטרטגיות הגנה מומלצות

- **סגמנטציה (Segmentation):** בידוד כל ספק חיצוני בסגמנט (מקטע רשת) נפרד עם הרשאות מינימליות, כדי שניתן יהיה לנתקו מבלי להשבית את כל הארגון במקרה של פריצה¹².
 - **יתרון ה-SaaS:** המרצה הסביר כי עדיף להשתמש במוצרי תוכנה כשירות (SaaS) על פני התקנות מקומיות (On-Prem), כיוון שהם מתעדכנים אוטומטית בחבילות אבטחה חדשות (Security Packages) כל כמה שבועות¹³.
 - **ניהול סיכונים בבחירת ספקים:** כיום ארגונים בוחרים ספקים לא רק לפי מחיר, אלא לפי רמת האבטחה, עמידה בתקנים (כמו SOC 2 או ISO) ותוצאות של מבחני חדירה (Penetration Testing)¹².
- השיעור הסתיים בדגש על כך שרוב התקיפות המודרניות מחפשות אנומליות וחוזרות על עצמן עד למציאת פרצה בשרשרת האספקה או בהגדרות לא נכונות (Misconfigurations) של המערכת^{1, 3, 9}.